

SecureOrg Inc.

PCI DSS Compliance Framework

Hardening Procedures

Document Reference:	HP-007
Version:	1.6
Effective Date:	April 14, 2026
Document Owner:	Chief Technology Officer
Classification:	CONFIDENTIAL
Review Cycle:	Annual
Framework:	PCI DSS v4.0

This document contains confidential and proprietary information. Unauthorized disclosure is prohibited.

1. Purpose and Scope

1.1 Purpose

This document defines the system hardening procedures for all components within SecureOrg Inc.'s cardholder data environment and connected systems. Hardening reduces the attack surface of systems by removing unnecessary functionality and configuring security settings to their most secure viable state. These procedures implement PCI DSS v4.0 Requirement 2 (Apply Secure Configurations to All System Components).

1.2 Scope

These procedures apply to all servers, workstations, network devices, databases, applications, and virtual and cloud infrastructure components in or connected to the CDE. Procedures must be applied before any system component enters the production environment.

1.3 Baseline References

Hardening procedures are derived from: CIS Benchmarks (Level 2 for CDE systems), DISA

STIGs where applicable, NIST SP 800-70 (National Checklist Program), and vendor security hardening guides. The Configuration Management Policy (CMP-005) governs configuration baselines and compliance monitoring.

2. General Hardening Principles

2.1 Default Security Posture

All systems must begin from a default-deny security posture:

- Start with a minimal, clean base image from the approved image library
- Remove or disable all unnecessary software packages, services, and components
- Enable only the services, ports, and protocols explicitly required for the system's function
- Change all default credentials before connecting to any network
- Enable comprehensive logging and auditing before going live
- Apply the approved configuration baseline and achieve at least 95% compliance score
- Register the system in the CMDB with its approved configuration documented

2.2 Unnecessary Services and Functions

For each system, the following categories must be reviewed and unnecessary items removed or disabled:

- Network services: web servers, FTP, Telnet, SMTP, DNS, NFS unless explicitly required
- Administrative services: SNMP (upgrade to v3 if required), remote management interfaces
- Scripting environments: PowerShell (restrict execution policy), Python, Perl on CDE systems unless required
- Compilers and development tools on production systems
- File sharing services and protocols (SMBv1 must be disabled)
- Guest accounts and default accounts

3. Windows Server Hardening

3.1 Operating System Hardening

Apply the following settings to all Windows Server deployments in the CDE:

- Apply all available security patches before deployment; maintain current patch state
- Enable Windows Defender or approved endpoint security software
- Configure Windows Firewall with approved rule sets; disable the profile not in use
- Enable BitLocker or approved FDE solution on all server volumes
- Disable or remove the following: SMBv1, NetBIOS over TCP/IP, LLMNR, WPAD
- Disable Remote Desktop Protocol (RDP) unless required; if required, restrict to approved source IPs
- Configure NTP to sync with approved internal time servers
- Enable and configure Windows Event Logging per the logging standard

3.2 Account and Password Settings

Configure the following via Group Policy for CDE systems:

- Rename and disable the built-in Administrator account; create a named admin account
- Disable the Guest account and all other unused built-in accounts
- Password complexity: enabled; minimum length: 12; maximum age: 90 days; history: 12
- Account lockout: 6 attempts; lockout duration: 30 minutes; observation window: 30 minutes
- Interactive logon: require Ctrl+Alt+Delete; do not display last username
- Restrict local logon to authorized administrators only

3.3 Audit Policy

Enable the following audit policies on all CDE Windows systems:

Account Logon	Success and Failure	Req 10.2.1
Account Management	Success and Failure	Req 10.2.1
Directory Service Access	Failure	Req 10.2.1
Logon/Logoff	Success and Failure	Req 10.2.1
Object Access	Success and Failure (CHD objects)	Req 10.2.1
Policy Change	Success and Failure	Req 10.2.1
Privilege Use	Success and Failure	Req 10.2.1
System Events	Success and Failure	Req 10.2.1

4. Linux Server Hardening

4.1 OS-Level Hardening

- Install minimal OS; no GUI or desktop environment on servers
- Apply all available security patches at build time using the approved patch management process
- Enable and configure SELinux or AppArmor in enforcing mode
- Configure and enable host-based firewall (iptables/nftables) with default-deny rules
- Disable IPv6 if not required; configure if required
- Disable Ctrl+Alt+Delete rebooting via systemd or /etc/inittab
- Set kernel parameters: disable IP forwarding (net.ipv4.ip_forward=0), enable SYN cookie protection, disable ICMP redirects

4.2 SSH Hardening

Configure /etc/ssh/sshd_config with the following settings:

- Protocol 2 only; disable Protocol 1
- PermitRootLogin no — root must use sudo from named accounts
- PasswordAuthentication no — key-based authentication only for remote access
- MaxAuthTries 3; LoginGraceTime 30
- AllowUsers / AllowGroups — restrict SSH access to authorised accounts/groups
- X11Forwarding no; PermitUserEnvironment no; UseDNS no
- Ciphers: aes256-ctr,aes192-ctr,aes128-ctr; MACs: hmac-sha2-512,hmac-sha2-256
- Banner /etc/issue.net — display approved warning banner

4.3 File System and Permissions

- Ensure /tmp, /var/tmp, /dev/shm are mounted with noexec, nosuid, nodev options
- Set sticky bit on all world-writable directories
- Restrict /etc/passwd, /etc/shadow, /etc/group permissions
- Ensure no world-writable files exist in critical directories
- Enable auditd and configure audit rules per the logging standard
- Configure logrotate for all application and system logs

5. Database Hardening

5.1 General Database Hardening

Apply the following hardening principles to all database platforms hosting CHD:

- Run database services under a dedicated, non-privileged service account
- Remove sample databases, schemas, and test accounts before production deployment
- Change all default database credentials
- Restrict network connections to the database to application servers and DBA jump hosts only
- Enable database audit logging for all access to CHD tables/schemas
- Implement database activity monitoring (DAM) for real-time threat detection

5.2 Database User Privilege Minimization

- Application accounts shall have only INSERT, SELECT, UPDATE, DELETE on required tables; no DDL permissions
- Reporting and read-only accounts shall have SELECT permissions only
- DBA accounts shall not be used by application services
- The database SA or root account shall be renamed and used only in break-glass scenarios
- Audit all use of elevated database privileges

6. Network Device Hardening

6.1 Firewall and Router Hardening

- Disable all unnecessary management services (HTTP, SNMP v1/v2c, Telnet, finger)
- Enable SSH v2 for management; restrict source IPs to management network
- Implement SNMPv3 with authentication and encryption if SNMP is required
- Configure centralized logging to the SIEM for all connection and rule-match events
- Implement MD5 or stronger authentication for routing protocols (OSPF, BGP)
- Disable IP source routing and directed broadcast
- Enable port security on access ports; disable unused switch ports

6.2 Network Segmentation Verification

Network segmentation controls must be tested at least every 6 months per PCI DSS Requirement 11.4.5:

- Verify that CDE VLANs/segments cannot communicate with non-CDE segments except

through approved firewall rules

- Test all firewall boundary points using penetration testing techniques
- Verify that compromised non-CDE systems cannot reach CHD systems through network controls
- Document and retain segmentation test results as PCI DSS compliance evidence

7. Endpoint Hardening

7.1 Workstation Hardening

- Deploy and maintain approved endpoint detection and response (EDR) software
- Enable full disk encryption (BitLocker, FileVault, or equivalent)
- Configure automatic screen lock after 5 minutes of inactivity in CDE areas
- Restrict USB and removable media access on CDE workstations
- Implement application whitelisting on CDE workstations
- Disable AutoRun/AutoPlay for removable media
- Configure browser security settings per the approved browser hardening guide

7.2 Point-of-Interaction (POI) Device Security

POI devices (card readers, POS terminals) in the physical CDE require:

- Regular inspection for evidence of skimming devices or tampering (at least monthly per PCI DSS Req 9.9)
- Device inventory with serial numbers maintained and verified quarterly
- Staff training to recognize and report suspected tampering
- Physical protection to prevent unauthorized access to device internals

8. Revision History

1.0	Jan 15, 2024	Initial release	CTO Office
1.3	Jul 22, 2024	Added database and cloud hardening; SSH hardening updates	Security Team
1.6	Apr 14, 2026	Annual review; POI device section; network segmentation testing	CTO/CISO